网络信息安全

期末考试复习指南

零基础系统版｜基于课程七个实验

学习目标｜以七个实验为课程范围锚点，建立基础概念、原理、操作、关联和考试表达能力。材料不假定读者听过课堂 PPT。

版本说明：本指南依据用户提供的七个实验原始说明书，以及此前整理的初学者指南、实验分析文档编写。实验原文没有明确覆盖的内容会标注为“基础补充”或“延伸理解”，不将其冒充教师指定考点。

重要边界：实验说明与配套资料不能保证覆盖教师期末试卷全部内容。本文旨在提高对实验相关知识的掌握程度，不承诺具体考试分数。

使用说明与课程全景

1. 这门课可以怎样理解

七个实验并不是七个互不相关的软件操作。它们大致构成一条从网络环境、主机管理、服务器防护、通信观察，到密码学信任和容器部署的学习路线。

实验	主题	核心问题	主要工具/对象
1	构建虚拟局域网	怎样搭建可控、可重复的网络实验环境？	VMware 等虚拟机软件、虚拟网卡、ping
2	常用网络安全管理工具	怎样查看网络配置、连接、端口、账户和计划任务？	Windows CMD、ping、ipconfig、netstat、net、at
3	Web 服务器安全	怎样保护服务器文件、端口、系统策略和网站访问？	NTFS、端口限制、MMC、安全模板、IIS
4	网络漏洞检测	怎样捕获并分析网络数据，识别明文凭据风险？	Sniffer / Wireshark、FTP、混杂模式、过滤器
5	密码应用	怎样让发送者向接收者安全发送文件？	PGP / OpenPGP、GnuPG、密钥对
6	公钥基础设施	怎样证明公钥属于它声称的身份，并管理证书？	PKI、CA、CSR、X.509、OpenSSL、CRL
7	Docker 及其应用	怎样封装、运行、部署和保护容器化应用？	Docker、镜像、容器、网络、数据卷

2. 建议学习顺序

1. 先学第一部分的网络与安全基础，尤其是 IP、TCP/UDP、端口、DNS、HTTP、机密性/完整性/可用性。
2. 再学实验 1—4：把网络环境、主机命令、服务器配置和抓包连成一条线。
3. 接着学实验 5—6：先理解密码学，再理解 PKI 如何为公钥建立身份信任。
4. 最后学实验 7：掌握容器模型、基本命令、部署流程和安全边界。
5. 每章学完先闭卷复述，再做章节自测；最后用综合题检验跨章节迁移能力。

3. 内容层级标记

标记	含义	学习要求
核心	原始明要求，或配套材料反强的核心念	能定义、解释原理、辨析并回答简答题
基础补充	理解实验必须具备的网络、系统或密码学前置知识	能用自己的话解释，能联系实验
延伸	实验原文未必要求，但有助于理解安全背景或现代实践	理解用途与边界，不必死记所有细节

第一部分｜网络与信息安全基础

1.1 计算机网络是什么

计算机网络是通过通信链路和网络设备连接起来、能够交换数据的计算机与终端系统集合。网络通信至少涉及通信双方、地址、传输规则和承载数据的链路。实验 1 让多台虚拟主机接入同一虚拟网络；实验 2 查看主机网络配置；实验 3 部署 Web 服务；实验 4 观察实际数据包。

1.2 IP 地址、子网掩码、网关和 MAC 地址

概念	作用	容易混淆的地方
IP 地址	在 IP 网络中标识网络接口，用于跨网络址	不是用户姓名，也不一定永久固定
子网掩码/前缀	划分网络部分与主机部分，判断地址是否处于同一子网	255.255.255.0 通常对应 /24
默认网关	把发往本地子网之外的数据交给下一跳路由设备	没有正确网关可能导致本地可通、外网不可达
MAC 地址	链路层接口地址，在本地链路传输中用于帧交付	与 IP 层地址不同；路由转发时链路层地址会变化

例：192.168.56.10/24 与 192.168.56.11/24 通常处于同一子网。这个例子只说明地址规划，不是课程规定的固定地址。若两台主机不在同一子网，通常需要路由器/网关转发才能通信。

1.3 TCP/IP 分层与常见协议

层次（简化）	主要职责	常见协议/容
应用层	为应用提供网络服务与数据格式	HTTP、HTTPS、FTP、DNS、SSH、SMTP
传输层	进程间通信、端口复用；TCP 提供可靠字节流，UDP 提供数据报	TCP、UDP
网络层	逻辑寻址与跨网络转发	IP、ICMP
链路层	同一链路上的帧传输	Ethernet、Wi-Fi、MAC

常见封装关系：应用数据 → TCP/UDP 段/数据报 → IP 数据包 → 链路层帧。Wireshark 会按协议层次解码捕获到的数据。不同教材对网络模型分层名称可能略有差异，重点是理解每层解决的问题。

1.4 TCP、UDP、端口

比较	TCP	UDP
连接方式	面向连接，通信前建立连接	无连接，不先建立类似 TCP 的连接
可靠性	提供确认、重传、按序交付等机制	协议本身不保证可靠交付和顺序
数据形式	字节流	数据报
典型用途	网页、文件传输、远程登录等需要可靠传输的场景	实时音视频、DNS 查询等适合低开销或应用自行处理可靠性的场景

端口号用于区分同一主机上的不同网络服务/进程。IP 地址回答“哪台主机/接口”，端口回答“该主机上的哪个服务端点”。常见默认端口：FTP 控制连接 TCP 21、HTTP TCP 80、HTTPS TCP 443、远程桌面 RDP TCP 3389。实际端口可以被配置更改，端口号本身不证明服务身份。

1.5 ICMP、ping 与 tracert

ICMP 是 IP 网络中的控制与差错报告协议。ping 通常发送 ICMP Echo Request 并等待 Echo Reply，用于判断目标是否对探测作出响应，并观察往返时间和丢包。

> **考试易错**｜ping 通不代表 TCP 80 端口开放，也不代表 IIS/FTP 服务正常；ping 不通也不一定代表主机离线，防火墙或网络设备可能屏蔽 ICMP。

tracert 通过逐步增加 IP 数据包 TTL，观察沿途路由设备返回的信息，从而显示到目标的大致路径。某一跳超时可能只是设备不响应探测，不一定表示端到端通信中断。

1.6 DNS 与 DHCP

协议	全称/用途	排障关联
DNS	域名系统，将域名解析为 IP 地址	能访问 IP、不能访问域名时应检查 DNS
DHCP	动态主机配置协议，自动分配 IP、子网掩码、网关、DNS 等参数	地址错误或租约异常时可检查 DHCP；ipconfig /renew 可请求更新自动获取的配置

1.7 信息安全三大目标与常见服务

目标	含义	例子
机密性 Confidentiality	防止未授权者读取信息	加密、访问控制
完整性 Integrity	防止或发现信息被未授权修改	哈希校验、MAC、数字签名
可用性 Availability	保证授权用户在需要时可使用系统和数据	备份、冗余、抗拒绝服务、故障恢复

身份认证回答“你是谁”；授权回答“你能做什么”；审计回答“发生了什么”。加密主要保护机密性，但并不自动提供所有安全目标。访问控制、签名、日志、备份等机制承担不同职责。

1.8 常见威胁与防护思路

威胁	含义	典型防护思路
窃听	未经授权读取通信内容	TLS、加密、网络隔离
篡改	未经授权修改数据	MAC、数字签名、完整性校验
冒充	伪装成合法用户/服务器	身份认证、证书验证、多因素认证
拒绝服务	耗尽资源使服务不可用	限流、冗余、过滤、监控
权限滥用	账户获得或使用超出需要的权限	最小权限、分权、审计

第二部分｜实验 1：构建虚拟局域网

2.1 实验目标与原文要求

原始实验要求使用 VMware 等软件构建虚拟局域网，在一台计算机中安装多台虚拟主机，为网络安全实验做准备；虚拟主机名使用本人姓名全拼，多台主机可在姓名后加数字；虚拟机之间应能够互相 ping 通。实验强调虚拟环境可以保护或恢复物理网络系统，并能在一台机器上同时运行多个操作系统。

2.2 物理主机、虚拟机与虚拟网络

对象	解释	关系
物理主机/宿主机	实际运行虚拟化软件的计算机	提供 CPU、内存、磁盘、网卡等资源
虚拟机 VM	由软件模拟、拥有虚拟硬件并运行独立操作系统的计算机	多个 VM 可运行在同一物理主机上
虚拟网络	虚拟化软件提供的虚拟交换/连接机制	让 VM 彼此通信，或与宿主机/外部网络通信

2.3 三种网络模式

模式	基本含义	适用景
Host-only	虚拟机通常只与宿主机及同一虚拟网络中的虚拟机通信	适合相对隔离的内部实验网；通常不能直接访问外部网络
NAT	虚拟机通过宿主机地址转换访问外部网络	适合需要下载软件、同时减少外部主动访问 VM 的场景；具体入站可达性取决于转发配置
Bridged 桥接	虚拟机像独立设备一样接入物理局域网	可能暴露在校园网/公共局域网中；未经许可不要使用

2.4 实验操作与验证思路

6. 创建至少两台虚拟机，分别安装操作系统，按实验要求设置主机名。
7. 将两台虚拟机的虚拟网卡连接到同一虚拟网络，确认网卡已连接。
8. 在两台虚拟机中查看 IP 地址和子网掩码，确认地址不冲突、网络规划合理。
9. 使用 ping 对方 IP 地址进行双向连通性测试。
10. 若失败，按顺序检查虚拟机状态、网卡连接、网络模式、IP/掩码、路由和防火墙 ICMP 规则。

2.5 故障分析

现象	可能原因	排查
两台 VM 无法互 ping	网络模式不同、虚拟网卡断开、IP 不在同一子网、地址冲突	检查虚拟网络选择、ipconfig/ip addr、子网掩码
能 ping 网关但不能 ping 对端	对端防火墙屏蔽 ICMP、对端网卡或地址配置问题	检查对端状态与 ICMP 策略
能 ping IP 但不能 ping 域名	DNS 配置/解析问题	检查 DNS 服务器、域名拼写和解析结果

ping 通但网页打不开	应用端口关闭、防火墙阻断、服务未启动、绑定或权限错误	转入端口与应用层排查

必须记住｜虚拟局域网的价值是建立可控、可重复、相对隔离的实验场地。它不是让真实网络免于所有风险的绝对安全保证。

第三部分｜实验 2：常用网络安全管理工具

3.1 实验目标与原文内容

原始实验包括：网络连通性及端口扫描；显示网络配置信息及设置；显示连接监听端口；查询与删改用户信息；创建计划任务。实验背景强调通过 ipconfig/netstat 定位网络配置异常，识别开放端口风险，强化用户权限管理意识，并了解自动化任务。

3.2 命令总表

命令/工具	用途	关键理解
ping	ICMP 连通性测试	测试 IP 层响应，不测试 TCP 应用端口
tracert	观察路由路径	利用 TTL 递增观察中间路由器
Quickping	快速探测网络中主机	主机发现类工具；具体行为依软件版本
Whois	查询域名/注册信息	不是通用端口扫描命令
端口扫描工具	探测目标 TCP/UDP 端口状态及可能服务	仅能在授权目标范围内使用
ipconfig	查看本机 IP 配置	可看 IP、子网掩码、默认网关
ipconfig /all	查看详细配置	包括 DHCP、DNS、物理地址等
ipconfig /renew	更新 DHCP 自动获取配置	只适用于 DHCP 自动获取的接口
netstat -an	查看活动连接和监听端口	-a 显示连接/监听，-n 数字显示地址端口
net user	查看/管理本地用户账户	修改账户属于敏感操作
net localgroup	查看/管理本地组	管理员组成员拥有较高权限
net use	查看/管理网络共享连接	凭据和远程访问须受授权控制
at / schtasks	计划任务管理	at 为旧式命令，现代 Windows 通常使用 schtasks

3.3 ipconfig：读懂本机网络配置

```
ipconfig
ipconfig /all
ipconfig /renew
```

ipconfig 显示网络适配器的基本 IP 配置；/all 显示更完整信息，如 DHCP 状态、DNS 服务器和物理地址；/renew 请求 DHCP 更新自动分配的配置。不要把 /renew 当作修复所有网络故障的万能命令。

3.4 netstat：连接与监听端口

```
netstat -an
```

状态	含义	判断时注意
LISTENING	TCP 端口处于监听状态，等待连接请求	表示有服务/程序监听，不自动等于入侵
ESTABLISHED	TCP 连接已经建立	需结合对端地址、进程、时间和业务判断
TIME_WAIT	连接关闭后的等待状态	通常是 TCP 正常关闭过程的一部分
CLOSE_WAIT	本端收到对端关闭信号，等待本地应用关闭	大量长期存在时可调查应用是否未及时关闭连接

netstat 是初步观察工具。判断异常连接需要结合进程归属、程序路径、主机基线、用户行为、安全日志和网络环境。陌生端口不自动等于恶意程序；常见端口也不保证安全。

3.5 net user 与 net localgroup：账户和权限

```
net user
net user 用户名
net localgroup
net localgroup administrators
```

用户账户用于识别主体，用户组用于集中组织权限。Administrators 组通常拥有较高系统权限。实验原文展示创建用户、修改密码、将用户加入管理员组等操作。其考试重点不是鼓励照搬命令，而是理解账户管理与权限边界。

> **安全提醒**｜实验材料中的 123456 是弱密码示例，不应在真实系统使用。不要为了测试在生产设备上创建账户或把普通用户加入管理员组。

3.6 net use、IPC$ 与计划任务

```
net use \\主机名或 IP\IPC$ /user:用户名
net use * /delete
```

net use 用于查看或管理 Windows 网络连接。IPC$ 是 Windows 特殊管理共享，与远程管理和身份验证相关。建立连接不代表自动取得对方全部权限，后续操作受账户身份、授权、系统策略和服务配置约束。原始实验的远程示例使用管理员凭据建立 IPC$ 连接并执行远程操作，具有明显风险，只应在明确授权的隔离实验环境中理解和演示。

原始实验使用 at 命令在远程主机创建定时任务。AT 是旧式计划任务工具，现代 Windows 中已用或不再可用，通常由 schtasks 等机制替代。计划任务可用于自动运维，也可能被恶意软件用于持久化；检查时应关注触发时间、运行账户、执行程序路径和创建来源。

3.7 端口扫描与工具边界

端口扫描通过向目标主机的 TCP/UDP 端口发送探测，根据响应推测端口状态或服务。它与 ping 不同：ping 主要观察 ICMP 响应，端口扫描观察传输层端口。实验原文提及 Quickping、Tracert/TraceRoute、Whois、SATAN、NSS、Strobe、Superscan 和 SNMP 等工具或技术；它们并非同一类别，部分名称属于较早期工具。

> **授权原则**｜扫描、账户管理、远程连接和计划任务操作只能在自己拥有或明确获准的设备与隔离实验网络中进行。

3.8 典型考试问答

问：为什么 netstat -an 出现 LISTENING 不代表主机被入侵？答：LISTENING 只说明某 TCP 端口有程序等待连接，可能是正常服务。判断风险还要确认进程、程序路径、服务用途、访问来源、主机基线和日志。

问：ping 通但服务不可访问，可能是什么原因？答：ping 测试 ICMP/IP 层响应，不验证应用服务端口；服务可能未启动、端口未监听、防火墙阻断、绑定错误或应用权限不足。

问：DHCP 与 DNS 有何区别？答：DHCP 自动分配网络参数；DNS 把域名解析为 IP 地址。

第四部分｜实验 3：Web 服务器安全设置

4.1 原始实验任务

原始实验要求：检查实验机器文件系统和各盘安全属性；对端口进行限制，在 IIS 上生成网页并限制 80 端口，由同伴机器访问并观察结果，其他端口类似；运行 MMC 进行安全模板配置；设置 IIS 新网站、添加实验网页并实施安全访问控制。

4.2 Web 服务工作流程

11. 用户在浏览器输入 URL；若使用域名，客户端先通过 DNS 获取服务器 IP。
12. 浏览器与服务器建立 TCP 连接，传统 HTTP 通常使用 TCP 80，HTTPS 通常使用 TCP 443。
13. IIS 接收 HTTP/HTTPS 请求，根据站点绑定、主机名、端口和路径决定由哪个网站处理。
14. 服务器进程按配置和访问权限读取网站资源，返回网页或错误响应。

网页可访问性由多层共同决定：网络路径、DNS、TCP 端口、防火墙、IIS 服务状态、站点绑定、身份验证、目录权限和应用程序状态。不能只检查 IIS 是否启动。

4.3 文件系统、NTFS 与 ACL

NTFS 是 Windows 常见文件系统，支持访问控制列表 ACL。ACL 通过用户或组主体配置读取、写入、修改、执行等权限。网站进程需要读取网页文件，但不应无理由获得整个磁盘或网站目录的广泛写入权限。

概念	含义	安全意义
NTFS	Windows 文件系统，支持权限与其他管理能力	为文件和目录提供访问控制基础
ACL	访问控制列表，列出主体及其允许/拒绝权限	明确谁可以读取、写入、修改或执行
最小权限原则	主体只获得完成任务所需的最低权限	降低网站进程被攻陷后的影响范围

SYSTEM / Administrators	常见系统/管理员安全主体	权限强，不能随意授予普通用户或服务

4.4 端口控制

端口	常见服务	安全思路
21/TCP	FTP 控制连接	不需要 FTP 时关闭或限制；明文 FTP 有凭据暴露风险
80/TCP	HTTP	按业务需要开放；若需加密应配置 HTTPS
443/TCP	HTTPS	正确配置 TLS 证书、协议和访问策略
3389/TCP	远程桌面 RDP	限制来源、启用强认证、避免对不可信网络直接暴露

端口限制应基于业务需要和访问范围，而不是盲目关闭。关闭 80 端口会使传统 HTTP 访问失败，但不代表 IIS 网站本身已经被删除或服务程序已停止。若使用 HTTPS，应检查 443 端口和 TLS 配置。

4.5 MMC 与安全模板

MMC（Microsoft Management Console，微软管理控制台）是承载管理单元的管理框架。安全模板可用于定义一组系统安全配置，例如账户策略、用户权限分配、安全选项、事件日志或文件系统权限等，具体项目取决于系统版本与模板内容。

安全模板有助于配置或分析安全基线，但应用模板并不意味着服务器绝对安全。应查看配置内容、应用结果和日志，并在变更前理解可能影响。旧版实验界面与现代 Windows 版本可能不同。

4.6 IIS 网站与访问控制

IIS 是 Windows 的 Web 服务器平台。建立网站通常涉及网站名称、物理路径、绑定信息（IP/端口/主机名）、应用程序池、身份验证方式和目录访问权限。不同版本 IIS 的界面与选项可能变化。

排查层次	容	典型问题
网络层	客户端与服务器是否可达、路由是否正确	网络不通、网关错误
端口层	目标端口是否监听、防火墙是否放行	80/443 被阻断
IIS 层	服务是否启动、站点是否启动、绑定是否匹配	绑定到错误 IP/端口/主机名
身份验证层	匿名/Windows 等身份验证配置是否符合预期	身份验证失败、权限不足
文件系统层	网站进程是否有读取目录/文件的权限	403 或访问拒绝

旧资料提示｜实验参考包含较旧 Windows/TCP-IP 筛选、ActiveX、Java 浏览器插件等设置。考试应理解安全配置原理；实际操作不要不加判断地照搬旧版界面或规则。

第五部分｜实验 4：网络漏洞检测与流量分析

5.1 实验目标、环境与角色

原始实验要求使用 Sniffer（NAI）或 Wireshark 捕获网络信息数据包，通过解码进行检测分析，并写出结论。实验设计三台 PC：A 机（示例 IP 10.0.0.3）由用户 Zhao 登录 FTP；B 机（10.0.0.4）运行已搭建的 FTP 服务器；C 机（10.0.0.2）由用户 Tom 使用 Sniffer 捕获 A 机的账号和密码。以上 IP 和用户名是实验示例，不是固定配置。

5.2 抓包、解码与混杂模式

包工具所适配器接收据。解是根据格式解据字段，不等于破解加密。混模式（Promiscuous Mode）允许网卡把它实际能够接收到的更多帧交给系统处理，但不代表它可以自动看到交换式网络中所有其他端口的单播流量。

在交换机网络中，若 C 机要观察 A 与 B 之的播通信，通常需要在受控交机上配置端口像（SPAN），把相关端口流量复制到分析端口。传统集线器的广播特性不同，但现代网络通常使用交换机。

5.3 实验流程

15. 在 C 机安装 Sniffer 或 Wireshark，选择正确的网络适配器。
16. 按原实验指导启用混杂模式（在能够支持且有授权的环境中）。
17. 创建捕获过滤器配置文件，例如原文中的 ftp_test。
18. 在 Address 选项卡中选择 IP 地址类型，并指定 A、B 两台主机地址。
19. 在 Advanced 选项卡中选择 FTP 协议，减少无关流量。
20. 开始捕获；A 机使用临时测试账号登录 B 机 FTP 服务。
21. 停止捕获，使用协议解码/专家分析功能检查 FTP 控制连接中的认证交互。
22. 记录捕获条件、观察到的协议字段和安全结论。

5.4 捕获过滤器与显示过滤器

类型	作用	使用时机
捕获过滤器	在采集时限制哪些数据包被保存，减少采集量	开始抓包前设置，如只捕获指定主机/协议
显示过滤器	对已经捕获的数据包进行筛选显示，不改变原始捕获文件	抓包后分析，如只显示 FTP 相关流量

原实验 Sniffer 通过地址与协议条件配置捕获过滤器。Wireshark 使用的过滤器语法与 Sniffer 界面不同，不能直接把旧软件的点击步骤等同于现代 Wireshark 操作。

5.5 FTP 明文认证风险

传统 FTP 通常使用独立控制连接传输命令和认证信息。其用户名、密码等控制信息在未启用保护的情况下可能以明文形式传输，因此网络路径上的观察者可能从捕获数据中读取凭据。实验通过隔离环境中的临时账号演示这一风险。

协议/方式	保护特点	注意
传统 FTP	默认不加密控制连接中的用户名、密码和	不适合在不可信网络中传输敏感凭据

	命令	
FTPS	在 FTP 上结合 TLS 保护连接	需正确配置证书与客户端
SFTP	基于 SSH 的文件传输协议	不是 FTP 加 TLS；协议体系不同

考试重点｜抓包分析能说明明文协议的风险；若流量经过 TLS 加密，通常仍能观察到 IP、端口、时间、长度等元数据，但不能直接读出应用层明文，除非具备合法解密材料和正确配置。

5.6 实验局限与安全边界

混杂模式不能突破交换机隔离；抓包结果取决于网卡、网络拓扑、端口镜像、过滤器和捕获时间。只能在自有或明确授权的实验网络捕获流量，不得采集他人真实账号密码。Sniffer 是较早期工具，现代学习通常可使用 Wireshark。

第六部分｜实验 5：密码应用与 PGP / GnuPG

6.1 原始实验任务与通信角色

实验目标是学习使用 PGP 工具实现安全通信并理解过程，工具为 GnuPG。主机 A 是接收方：生成公钥和私钥、导出公钥、最终用私钥解密。主机 B 是发送方：导入 A 的公钥、使用它加密 TXT 文件、把密文发送给 A。原文还鼓励 B 对加密文档签名，并由 A 验证签名。

最重要方向关系｜如果目标是让 A 能读文件：B 使用 A 的公钥加密；A 使用与之配对的私钥解密。B 不需要也不应该获得 A 的私钥。

6.2 PGP、OpenPGP 与 GnuPG

名称	含义
PGP	Pretty Good Privacy，最初由 Phil Zimmermann 开发的加密软件及相关体系；也常被泛指此类文件/邮件安全方案
OpenPGP	将相关数据格式和密码学操作规范化的开放标准
GnuPG / GPG	GNU Privacy Guard，是 OpenPGP 标准的自由软件实现；本实验实际使用的工具

6.3 明文、密文、对称加密与非对称加密

明文是加密前可读数据；密文是加密变换后的数据。对称加密使用同一秘密密钥（或可相互推导的密钥）加密和解密，速度快，适合大数据量；缺点是双方需要安全共享密钥。常见现代算法包括 AES、ChaCha20。

非对称密码学使用数学上相关联的公钥和私钥。公钥可以公开，私钥必须保密。机密性用途下，发送方使用接收方公钥加密，接收方使用对应私钥解密。RSA 是经典算法，现代 OpenPGP 也支持其他公钥算法。

比较	对称加密	非对称密
密钥	共享秘密密钥	公钥与私钥成对

速度/用途	通常更快，适合加密大量数据	计算开销较高，常用于密钥封装、签名等
主要难点	如何安全分发共享密钥	如何确认公钥确实属于目标身份
本实验角色	加密文件主体的会话密钥	A 的公钥保护会话密钥

6.4 混合加密：PGP 的关键

23. 发送方为本次加密随机生成会话密钥（Session Key）。
24. 使用会话密钥和对称算法加密文件主体。
25. 使用接收方 A 的公钥加密或封装会话密钥。
26. 发送方将加密后的文件数据与受保护的会话密钥等信息组合成 OpenPGP 消息。
27. A 使用自己的私钥恢复会话密钥，再使用会话密钥解密文件主体。

混合加密不是单独一种算法，而是一种系统设计：对称算法负责高效加密数据，公钥密码学负责保护会话密钥。

6.5 哈希函数与完整性

哈希函数把任意长度输入映射为固定长度摘要。密码学哈希希望具备确定性、原像抗性、第二原像抗性和抗碰撞性。输入哪怕只改变一个字符，SHA-256 摘要也通常会明显变化（雪崩效应）。

普通摘要可以帮助发现数据变化，但若攻击者能同时替换文件和摘要，单靠摘要不能证明文件来自可信发送者。需要 MAC、数字签名或认证加密等机制来提供来源认证/完整性保护。MD5 和 SHA-1 已不适合现代安全场景中的抗碰撞用途。

6.6 数字签名

数字签名通常由签名者使用自己的私钥对消息摘要执行签名操作，接收者使用签名者公钥验证。验证成功可帮助确认签名与对应私钥匹配，并检测签名后内容是否被修改。签名不等于加密：签名文件仍可能公开可读。若既要机密性又要身份/完整性验证，需要组合加密与签名。

比较	加密	数字签名
主要目标	机密性：限制谁能读	来源认证/身份关联与完整性验证
典型方向	接收者公钥加密，接收者私钥解密	签名者私钥签名，验证者用签名者公钥验证
实验中的角色	主实验必做	补充实验鼓励完成

特别注意｜主实验只明确要求 B 用 A 的公钥加密、A 用私钥解密。A 成功解密不证明文件一定由 B 发送；只有按补充实验完成 B 的签名并由 A 验证，才能增加对发送者身份和内容完整性的验证。

6.7 公钥指纹、身份绑定与中间人攻击

公钥指纹是由公钥材料计算得到的短标识，便于通过独立可信渠道核对两份公钥是否相同。若攻击者在传递过程中替换 A 的公钥，B 可能使用攻击者的公钥加密；攻击者解密后再加密给 A，形成中间人攻击风险。因此公钥可公开，不等于任何来源的公钥都可信。

6.8 GnuPG 原始实验命令

步骤	示例命令	作用
验证安装	gpg --version	查看 GnuPG 版本，确认命令可用
生成密钥	gpg --full-generate-key	生成公钥/私钥；按实验选择 RSA、密钥长度和有效期等
导出公钥	gpg -a -o mypublickey.asc --export user-id	将 A 的公钥导出为可传输文本文件
导入公钥	gpg --import mypublickey.asc	在 B 的密钥库中导入 A 的公钥
加密文件	gpg -r user-id --output encrypted.txt --encrypt plain.txt	指定 A 为接收者，使用 A 的公钥加密
解密文件	gpg --decrypt encrypted.txt > decrypted.txt	A 使用对应私钥解密并保存明文

原始过程版示例中的路径、邮箱、文件名和用户名需要替换成自己的实验值。导入公钥只表示本机保存了公钥，不自动证明其真实性。User ID 用于识别密钥，并不等于权威机构认证的真实身份。

6.9 密钥管理

- 公钥可以分发；私钥必须由所有者保管，不应通过普通渠道发送给通信对象。
- 私钥可能由口令短语（Passphrase）保护；口令短语主要保护本地私钥存储。
- 私钥丢失可能导致无法解密此前发给自己的数据；私钥泄露可能造成数据机密性或身份冒充风险。
- 应考虑私钥备份、更新、过期、撤销、设备迁移和访问控制。

第七部分｜实验 6：PKI 公钥基础设施

7.1 PKI 要解决什么问题

公钥密码学让公钥可以公开，但出现了身份问题：收到的公钥真的属于它声称的个人、组织或服务器吗？PKI（Public Key Infrastructure，公钥基础设施）围绕公钥、数字证书和信任关系建立技术、制度与流程，核心任务是借助可信 CA 将公钥与身份建立可验证的绑定，并管理证书生命周期。

7.2 PKI 的主要角色与对象

对象	作用/含义	注意
CA	证书颁发机构，审核申请并用 CA 私钥签发证书	CA 私钥必须严格保护
RA	注册机构，负责申请者身份登记、核验或审批	可与 CA 分离，也可能由同一组织承担
数字证书	由 CA 签名，绑定主体身份信息与公钥的数据结构	证书不应包含对应私钥
CSR	证书签名请求，包含申请者公钥和申请信息，通常由申请者签名	申请者生成并提交，CA 审核后决定是否签发
证书库/目录	存放、分发证书及相关信息	帮助证书使用者获取证书
CRL / OCSP	发布或查询证书吊销状态	帮助验证方判断证书是否仍可接受

7.3 数字证书字段

字段	含义
Subject	证书代表的主体，如域名、组织或个人
Issuer	签发证书的 CA
Public Key	与证书主体关联的公钥
Validity	证书有效起止时间
Serial Number	CA 用于区分证书的编号
Extensions	用途、主体备用名称 SAN、CA 能力等扩展
Signature	CA 对证书内容作出的数字签名

证书是公开的身份与公钥绑定文件，不是私钥。服务器向浏览器提供证书，并不意味着服务器把私钥交给浏览器。

7.4 CSR、签发与证书链

典型流程：申请者生成自己的密钥对 → 生成 CSR → CA/RA 核验申请 → CA 使用自己的私钥签发证书 → 服务器部署证书与私钥 → 客户端验证证书。

CSR 通常包含申请者公钥和主体信息，并由申请者使用对应私钥签名，证明申请者持有该私钥。CSR 不是证书，也不是私钥。

现实 PKI 常采用根 CA → 中间 CA → 终端实体证书的链式结构。客户端预先信任根 CA 证书，沿签发关系验证中间 CA 和网站证书。中间 CA 可分担签发任务，并帮助保护根 CA 私钥。

7.5 客户端如何验证证书

28. 检查证书签名能否沿证书链验证到本机信任的根 CA。
29. 检查证书是否处于有效期内。
30. 检查 Subject/SAN 是否匹配当前访问目标域名或 IP。
31. 检查 Key Usage、Extended Key Usage 等用途扩展是否适合当前场景。
32. 根据策略检查证书是否已被吊销。

常见陷阱｜证书签名验证成功不等于证书在任何场景下都可信；还要检查信任链、有效期、名称、用途和吊销状态。

7.6 自签名证书

自签名证书由证书对应私钥为自身证书签名。教学环境常创建自签名根 CA 证书，但自签名本身不会自动让其他计算机信任它；客户端必须通过可信方式把它配置为信任锚。

7.7 证书生命周期与吊销

证书生命周期通常包括申请、签发、部署/使用、更新、过期和吊销。证书可能在到期前因私钥泄露、错误签发、主体信息变化或组织策略改变而不再可信。吊销不是删除本地证书文件，而是由 CA 更新并发布状态信息，让验证方能够获知证书不应再被接受。

机制	含义	特点
CRL	CA 签名发布的证书吊销列表，包含已吊销证书序列号等信息	列表式发布，客户端获取并检查
OCSP	在线证书状态协议，可查询单张证书状态	通常返回 good、revoked 或 unknown 等状态

7.8 OpenSSL 命令与文件角色

命令	作用/考试理解
openssl version -a	查看 OpenSSL 版本与构建信息
openssl genpkey	生成私钥
openssl req -new	创建 CSR
openssl req -x509	生成自签名证书（需理解参数和扩展边界）
openssl x509 -in cert.crt -text -noout	以可读形式查看证书字段
openssl verify -CAfile ca.crt server.crt	按指定 CA 信任设置验证证书
openssl s_server / s_client	搭建/连接 TLS 测试服务，观察证书参与连接
openssl ca -revoke	在配置 CA 数据库的前提下吊销证书
openssl ca -gencrl	生成 CRL

文件	角色	谁应保管
ca.key	CA 私钥，用于签发证书	CA 严格保管
ca.crt	CA 证书，含 CA 身份与公钥	可分发给客户端建立信任
server.key	服务器私钥	服务器严格保管
server.csr	证书申请请求	提交给 CA，不是私钥
server.crt	CA 签发的服务器证书	可向客户端提供
index.txt / serial	OpenSSL CA 数据库与序列号文件	CA 管理环境维护
ca.crl	证书吊销列表	按策略发布

命令示例属于教学简化流程。完整 CA 需要配置文件、证书数据库、序列号、扩展和 CRL 参数；不同 OpenSSL 版本配置可能不同。仅复制 openssl ca -revoke 或 -gencrl 命令而未配置 CA 数据库，通常不能完成吊销。

7.9 PKI 与 PGP 的关系和区别

维度	PGP / OpenPGP	PKI
核心问题	怎样使用公钥加密/签名，实现安全通信	怎样建立公钥与身份的可信绑定并管理证书
信任建立	可通过指纹核验、信任网络等方式	通常通过 CA 签发证书和证书链

主要对象	用户密钥、消息、文件、签名	CA、RA、证书、证书链、吊销状态
实验工具	GnuPG	OpenSSL
共同基础	都使用公钥密码学、密钥对和数字签名等机制	都使用公钥密码学、密钥对和数字签名等机制

第八部分｜实验 7：Docker 及其应用

8.1 Docker 解决什么问题

Docker 用于封装应用及其运行所需环境，降低开发、测试和部署环境差异，使应用更容易交付、部署和迁移。原实验分三阶段：学习 Docker 原理、安装 Docker（前两项为必做）、在 Docker 中部署应用（例如开源防火墙，属于鼓励完成），并要求报告 Docker 基本内容及其与信息安全结合的场景。

8.2 镜像、容器、仓库与 Dockerfile

概念	定义	关系
镜像 Image	只读模板，包含应用运行所需文件、依赖和元数据	用于创建容器
容器 Container	镜像创建的运行实例，具有独立的进程/网络等隔离视图	一个镜像可创建多个容器
仓库 Registry	存储和分发镜像的服务	docker pull 从仓库获取镜像
Dockerfile	描述如何构建镜像的文本文件	docker build 根据它构建镜像
Volume	用于持久化保存容器数据的存储机制	将数据与容器生命周期分离

8.3 容器与虚拟机

比较	容器	虚拟机
运行基础	通常共享宿主机内核	每台 VM 通常运行独立客户机操作系统内核
隔离机制	Linux Namespace、Cgroups 等内核机制	虚拟化硬件与独立 OS 环境
资源开销	通常较轻量、启动快	通常开销更大、启动较慢
安全边界	共享内核，配置和内核漏洞可能影响宿主机	通常隔离边界不同且更强，但也非绝对安全
适用	应用封装、微服务、快速部署	运行不同 OS、需要较强隔离或完整系统环境

Namespace 隔离进程看到的资源视图（如进程、网络、挂载等）；Cgroups 对进程组的 CPU、内存等资源使用进行限制和统计。容器不是一台完整独立的虚拟机。

8.4 Docker 架构与安装验证

常见组件包括 Docker CLI（命令行客户端）、Docker Engine/daemon（接收请求并管理镜像、容器、网络、卷）、containerd 和 OCI runtime 等运行时组件。考试掌握大致职责即可，不必把组件实现细节混为一谈。

```
docker version
docker info
docker run hello-world
```

docker version 查看客户端/服务端版本信息；docker info 查看 Engine 运行信息；hello-world 通常拉取测试镜像并运行容器，成功输出欢迎信息可说明基本拉取和运行链路可用。Linux 上 Docker 管理权限较高；加入 docker 组通常意味着获得接近 root 的控制能力，不能视为普通低风险权限调整。

8.5 常用命令表

命令	用途
docker pull IMAGE:TAG	从仓库拉取镜像
docker images	查看本地镜像
docker run -d --name NAME IMAGE	创建并后台运行容器
docker ps	查看运行中的容器
docker ps -a	查看所有容器，包括已停止的
docker logs NAME	查看容器日志
docker exec -it NAME sh	进入运行中的容器执行命令（镜像需含 shell）
docker stop NAME	停止容器
docker rm NAME	删除容器对象
docker volume create NAME	创建数据卷
docker volume ls	查看数据卷
docker inspect NAME	查看容器详细配置

8.6 端口映射、网络和数据卷

示例 docker run -d --name web-demo -p 8080:80 nginx 表示把宿主机 8080 端口映射到容器 80 端口。EXPOSE 主要是镜像元数据中的端口声明，不会自动开放宿主机端口；实际发布通常需要 -p 等运行配置。

bridge 是常见默认网络方式，容器通过虚拟网桥通信；host 网络让容器使用宿主机网络命名空间，隔离性降低，端口与宿主机共享。端口映射要检查绑定地址和暴露范围，避免管理端口意外对外开放。

容器可写层通常随容器删除而消失。重要数据应使用 Volume 或外部存储，并建立备份和恢复流程。容器删除与数据卷删除不是同一件事。

8.7 Docker 与信息安全

景/□□	解释与防护
安全实验环境	快速启动隔离的测试服务，实验结束后清理；但需确认网络隔离边界
安全工具部署	部分日志分析、漏洞管理、入侵检测或访问控制组件提供容器

	镜像
镜像供应链	使用可信来源、固定版本、核对摘要/签名、扫描漏洞
最小权限	尽量非 root 运行，只授予必要 capability，避免 privileged
敏感信息	不要把密码、令牌、私钥写进 Dockerfile 或镜像层
端口暴露	审查 -p 映射和监听地址，防止内部管理服务暴露
数据持久化	用 Volume/外部存储并备份，避免容器重建丢失重要数据
宿主机风险	容器共享内核，及时更新宿主机内核、Engine 和运行时

容器可用于部分低风险、受控测试，但不能被视为强隔离恶意软件分析沙箱。高风险样本应使用专门隔离实验室、虚拟机快照、网络隔离和监控。

8.8 开源防火墙部署的判断

实验将开源防火墙作为部署应用示例，但并非所有防火墙都适合普通 Docker 容器。选择前需确认项目官方是否支持容器镜像、是否需要 NET_ADMIN/NET_RAW、主机网络、特权模式、内核模块或设备访问。某些以完整操作系统为基础的防火墙更适合虚拟机或专用硬件，不能未经确认就当作普通容器运行。

第九部分｜跨章节知识关联与易混淆概念

9.1 一张总知识地图

起点	发展/应用	关联到的实验
虚拟化与虚拟网络	搭建多主机实验环境，验证 IP 层连通性	实验 1
IP / ICMP / TCP / UDP / DNS / DHCP	查看配置、路由、端口和服务状态	实验 1、2
端口、账户、权限、计划任务	服务器暴露面、权限边界与运维风险	实验 2、3
HTTP/FTP 服务与文件权限	IIS 站点访问控制、端口放行和故障排查	实验 3
数据包、协议、明文与密文	抓包分析 FTP 认证风险，理解 TLS 的保护作用	实验 4、5、6
对称/非对称加密、哈希、签名	PGP 混合加密与消息认证	实验 5
公钥身份绑定、CA、证书链	HTTPS/TLS 证书验证和吊销	实验 6
镜像、容器、网络、卷、权限	容器化部署服务与容器安全	实验 7

9.2 高频易混淆概念

概念 A / B	核心区别	记忆提示
IP 地址 / MAC 地址	IP 用于网络层寻址；MAC 用于本地链路帧交付	跨网路由时 IP 通常保持端到端，链路 MAC 会逐跳变化
IP 地址 / 端口	IP 标识主机接口；端口区分主机上的服务端点	主机 + 端口定位通信服务
ping / 端口扫描	ICMP 响应测试 / TCP 或 UDP 端口探测	能 ping 不代表端口开放
LISTENING / ESTABLISHED	监听等待连接 / TCP 连接已建立	监听不是入侵证据
DNS / DHCP	域名解析 / 自动分配网络参数	一个找 IP，一个配置 IP

HTTP / HTTPS	HTTP 应用协议 / HTTP 结合 TLS 保护传输	HTTPS 不是另一套完全无关的 Web 协议
FTP / SFTP / FTPS	传统 FTP / 基于 SSH 的文件传输 / FTP+TLS	SFTP 不等于 FTPS
加密 / 哈希	加密可逆（持有密钥可解密）/ 哈希摘要通常不可逆	摘要不是密文
加密 / 数字签名	机密性 / 来源认证与完整性	接收者公钥加密；签名者私钥签名
公钥 / 证书	公钥是密码学密钥材料 / 证书将公钥与身份绑定并由 CA 签名	证书不是私钥
CSR / 证书	申请者提交的签发请求 / CA 签发的身份与公钥证明	CSR 不是已签发证书
CRL / OCSP	吊销列表 / 在线单证书状态查询	列表式 vs 按证书查询
镜像 / 容器	只读模板 / 运行实例	一个镜像可创建多个容器
容器 / 虚拟机	共享宿主机内核 / 通常运行独立客户机 OS	容器更轻，不等于天然更安全
docker stop / docker rm	停止容器 / 删除容器对象	停止不等于删除
EXPOSE / -p	镜像端口元数据声明 / 实际发布宿主机端口映射	EXPOSE 不自动对外开放

9.3 综合场景：网站无法访问如何排查

33. 先确认客户端 IP、子网掩码、默认网关和 DNS 是否正确（ipconfig）。
34. 检查能否 ping 服务器 IP；若失败，检查虚拟网络、路由和 ICMP 防火墙策略。
35. 检查目标 TCP 端口是否监听、是否被防火墙阻断（netstat、端口连通性测试）。
36. 检查 IIS 服务和网站状态、站点绑定、主机名与端口配置。
37. 检查网站目录 ACL，确认 IIS 工作进程身份具有所需读取权限。
38. 若使用 HTTPS，检查证书链、有效期、SAN 名称、用途和吊销状态。
39. 如服务运行于 Docker 容器，进一步检查容器状态、日志、网络、端口映射、挂载与运行权限。

9.4 综合场景：如何解释 FTP 密码被抓获

客户端向 FTP 服务器建立控制连接并发送登录命令。若使用传统未加密 FTP，认证信息可能以明文出现在网络数据中。分析端必须实际能够接收到相关流量；交换机环境可能需要端口镜像。Wireshark 按 FTP 协议解码后可显示认证交互。防护方式包括使用 SFTP 或 FTPS、避免在不可信网络使用明文 FTP、使用临时测试账号并保护抓包文件。

9.5 综合场景：HTTPS 证书为什么需要 PKI

TLS 需要确认通信对端身份并协商会话密钥。服务器提供证书，客户端验证证书链是否通向可信根 CA，并检查有效期、域名/SAN、用途和吊销状态。验证通过后再完成 TLS 握手，协商会话密钥并保护后续 HTTP 数据。证书用于身份与公钥绑定，不是用来直接加密整个网页内容。

第十部分｜考试答题方法与重点清单

10.1 简答题的通用结构

建议采用“定义 → 目的 → 原理/流程 → 作用或局限”的结构。比如问“什么是 PKI”，不要只写全称；还应说明它通过 CA 和数字证书建立公钥与身份的可信绑定，并管理证书签发、验证和吊销。

10.2 比较题的通用结构

先明确比较维度，再逐项对照：定义、密钥/对象、工作方式、目标、优缺点、实验应用。不要只写“一个快一个慢”或“一个安全一个不安全”，要说明原因。

10.3 场景分析题的通用结构

先描述现象，再分层定位：网络配置 → 路由/连通 → 端口/防火墙 → 服务/应用 → 权限/身份 → 加密与证书 → 日志与验证。每个结论都要给出可验证依据，避免仅凭一个命令输出断言被入侵或系统安全。

10.4 最优先掌握清单

- 网络基础：IP、子网掩码、默认网关、MAC、DNS、DHCP、TCP、UDP、ICMP、端口。
- 实验 1：Host-only、NAT、桥接的差别；虚拟机互 ping 的排障顺序。
- 实验 2：ping、tracert、ipconfig /all、ipconfig /renew、netstat -an、LISTENING、ESTABLISHED、net user、net localgroup、net use、IPC$、计划任务。
- 实验 3：IIS 请求流程、NTFS、ACL、最小权限、端口控制、MMC、安全模板、站点绑定与访问控制。
- 实验 4：三台主机角色、抓包、混杂模式、交换机端口镜像、捕获/显示过滤、FTP 明文风险、SFTP/FTPS。
- 实验 5：对称/非对称加密、混合加密、会话密钥、哈希性质、数字签名、公钥指纹、中间人攻击、GnuPG 步骤。
- 实验 6：PKI、CA、RA、CSR、X.509 字段、根/中间 CA、证书链验证、SAN、CRL、OCSP、OpenSSL 命令。
- 实验 7：镜像/容器/仓库/Dockerfile/Volume、容器与 VM、Namespace/Cgroups、端口映射、网络、常用命令、容器安全风险。

10.5 考前快速回忆口诀

主题	一句话回忆
网络寻址	IP 找主机，端口找服务，DNS 把域名解析为 IP，DHCP 自动分配网络参数
连通性	ping 看 ICMP 响应，tracert 看路径，端口扫描看传输层端口状态
主机状态	ipconfig 看配置，netstat 看连接与监听，net user/group 看账户与组
Web 安全	端口控制 + IIS 绑定/认证 + NTFS/ACL + 最小权限
抓包分析	选网卡 → 设过滤 → 捕获 → 解码 → 解释风险；交换机单播流量可能要镜像
PGP	接收方公钥加密，接收方私钥解密；对称加密数据，公钥保护会话密钥

数字签名	签名者私钥签，验证者用签名者公钥验；签名不等于加密
PKI	申请者生成密钥和 CSR，CA 签发证书，客户端验证链/名称/时间/用途/状态
Docker	镜像是模板，容器是实例；Namespace 隔离视图，Cgroups 管资源；Volume 保数据

第十一部分｜自测题与参考答案

A. 基础概念题

1. IP 地址和端口分别解决什么问题？

参考答案：IP 地址用于网络层定位主机接口；端口用于区分该主机上的不同传输层服务/进程端点。

2. DNS 与 DHCP 有什么区别？

参考答案：DNS 将域名解析为 IP 地址；DHCP 自动分配 IP 地址、子网掩码、网关和 DNS 等网络参数。

3. 为什么 ping 通不代表 Web 服务一定可用？

参考答案：ping 通常只说明目标对 ICMP Echo 探测有响应，不验证 TCP 80/443 端口、IIS 状态、站点绑定或文件权限。

4. netstat 中 LISTENING 和 ESTABLISHED 分别代表什么？

参考答案：LISTENING 表示 TCP 端口正在等待连接；ESTABLISHED 表示 TCP 连接已建立。

5. Host-only、NAT、桥接有何区别？

参考答案：Host-only 主要限于宿主机和虚拟网络内部；NAT 允许 VM 借宿主机外部；接使 VM 像局域网独立设备接入物理网络。

6. 什么是最小权限原则？

参考答案：用户或进程只获得完成任务所需的最低权限，以降低误操作和被攻陷后的影响。

7. 什么是混杂模式？

参考答案：网卡将其实际能够接收到的更多数据帧交给系统处理以供分析；它不能自动突破交换机端口隔离。

8. 为什么传统 FTP 登录凭据可能泄露？

参考答案：未启用加密保护的 FTP 控制连接可能以明文传输用户名、密码和命令，抓包分析可读出相关内容。

9. 什么是混合加密？

参考答案：用对称密钥加密大量数据，再用接收方公钥保护该会话密钥，兼顾效率与密钥分发安全。

10. 哈希和加密有什么区别？

参考答案：加密旨在通过密钥保护机密性并可由授权方解密；哈希将任意长度输入映射为固定长度摘要，通常不可逆。

11. 数字签名能提供什么？

参考答案：可帮助验证签名与对应私钥的关联，并检测签名覆盖的数据是否被修改；它本身不等于加密。

12. PKI 解决什么问题？

参考答案：通过 CA、数字证书和信任链建立公钥与身份之间的可验证绑定，并管理证书生命周期。

13. CSR 是什么？

参考答案：证书签名请求，由申请者生成，通常包含公钥和主体信息并由申请者签名，提交 CA 审核后决定是否签发证书。

14. CRL 和 OCSP 有什么区别？

参考答案：CRL 是 CA 签名发布的吊销列表；OCSP 是在线查询单张证书状态的协议。

15. 镜像和容器有什么区别？

参考答案：镜像是只读模板；容器是由镜像创建的运行实例。一个镜像可以创建多个容器。

B. 原理与分析题

16. 说明 PGP 文件加密的完整流程。

参考答案：A 生成密钥对并把公钥交给 B；B 导入并选择 A 的公钥；GnuPG 为本次加密生成会话密钥，用对称算法加密文件，再用 A 的公钥保护会话密钥；B 把密文发送给 A；A 用自己的私钥恢复会话密钥，再解密文件。

17. 为什么证书签名正确仍不能直接判定网站可信？

参考答案：还需检查证书链是否通向受信任根 CA、有效期、域名/SAN 是否匹配、证书用途是否适合 TLS 服务，以及是否已吊销。

18. 为什么 C 机可能无法捕获 A 与 B 的 FTP 流量？

参考答案：网卡只能捕获它实际接收到的帧；在交换机网络中，A 与 B 的单播流量通常只发往对应端口。需要在受控交换机上配置端口镜像，或使用合适的实验网络拓扑。

19. 说明网站访问失败的分层排查思路。

参考答案：先检查 IP/DNS/路由，再检查 TCP 端口与防火墙；然后检查 IIS 服务、站点绑定、身份验证和网站目录 ACL；若使用 HTTPS，还要检查证书链、域名、有效期和用途。

20. 为什么 Docker 容器不等于虚拟机，也不等于强安全沙箱？

参考答案：容器通常共享宿主机内核，利用 Namespace 隔离资源视图、Cgroups 管理资源；虚拟机通常有独立客户机 OS。容器轻量但共享内核，内核漏洞、特权配置和挂载错误可能影响宿主机。

C. 命令识别题

命令	应答要点
ipconfig /all	查看详细网络配置，包括 DHCP、DNS、物理地址等
netstat -an	查看活动连接和监听端口，以数字形式显示地址和端口
ping 目标 IP	通过 ICMP Echo 测试 IP 层响应
tracert 目标 IP	通过 TTL 递增观察到目标的大致路由路径
gpg --full-generate-key	生成 GnuPG 密钥对
gpg --import key.asc	导入公钥

openssl x509 -in cert.crt -text -noout	查看证书字段
openssl verify -CAfile ca.crt server.crt	按指定 CA 验证证书
docker ps -a	显示所有容器，包括已停止容器
docker run -d -p 8080:80 nginx	后台运行 Nginx，并将宿主机 8080 映射到容器 80

D. 综合模拟题

建议闭卷完成，答题时写出概念、原因、过程和结论。

40. 某虚拟机可以 ping 通默认网关，但无法访问同网段另一台虚拟机。列出至少四个排查方向。
41. 服务器 netstat 显示 TCP 80 为 LISTENING，但同伴浏览器无法打开网页。列出可能原因及检查顺序。
42. 抓包机开启混杂模式后仍看不到 FTP 客户端与服务器之间的数据。解释原因并给出实验环境调整方法。
43. 说明为什么 PGP 采用混合加密，而不是直接用 RSA 加密整个文件。
44. 某网站证书由可信 CA 签发且签名正确，但浏览器仍提示证书错误。列出至少四项检查。
45. 容器删除后业务数据丢失。解释原因并提出持久化方案。
46. 比较 PGP 与 PKI 的主要目标、信任建立方式和实验工具。
47. 说明容器部署安全工具时为什么需要关注镜像来源、运行权限、网络模式和数据卷。

模拟题参考答题要点

1. 检查两台 VM 是否接入同一虚拟网络；IP/掩码是否正确；是否存在地址冲突；对端是否启动；对端防火墙是否屏蔽 ICMP；路由和虚拟交换设置是否正确。

2. 检查客户端 DNS/目标地址；服务器网络可达；防火墙是否放行 80；IIS/站点是否启动；绑定 IP/端口/主机名是否匹配；身份验证和目录 ACL 是否允许访问。

3. 混杂模式只处理网卡实际收到的帧，交换机通常不把 A-B 单播流量复制给 C；配置受控端口镜像，确认 C 选对网卡，并检查捕获过滤条件。

4. 对称加密速度快且适合大数据；公钥算法开销较高且数据长度受限；因此对称密钥加密文件，接收方公钥保护会话密钥。

5. 检查有效期、域名/SAN 匹配、证书用途扩展、完整证书链、根 CA 是否在信任库、吊销状态、系统时间等。

6. 容器可写层随容器生命周期结束而删除；使用 Volume 或外部存储挂载持久化目录，并配置备份/恢复。

7. PGP 重点是用户之间的加密/签名通信，公钥身份可通过指纹或信任机制核验；PKI 重点是 CA 通过证书链建立身份与公钥绑定并管理生命周期；实验工具分别是 GnuPG 和 OpenSSL。

8. 镜像可能含漏洞或恶意代码；高权限/privileged 扩大宿主机风险；网络模式决定暴露边界；Volume 保存重要数据并需备份。

附录 A｜原始实验要求对照表

原始实验	明确要求/内容	本指南对应章节
实验 1	虚拟机软件构建虚拟局域网；多台虚拟主机；主机名使用姓名全拼；虚拟机互	第二部分

	ping 通	
实验 2	网络连通性及端口扫描；显示网络配置；连接监听端口；用户信息查询/删改；计划任务	第三部分
实验 3	检查文件系统和安全属性；端口限制；IIS 网页访问测试；MMC 安全模板；IIS 网站与访问控制	第四部分
实验 4	Sniffer 或 Wireshark；三台 PC；FTP 登录流量捕获；混杂模式；地址与 FTP 协议过滤；解码分析	第五部分
实验 5	GnuPG 安装；生成密钥对；导出/导入 A 公钥；B 加密 TXT；传输密文；A 解密；鼓励签名验证	第六部分
实验 6	Linux/Ubuntu 或 CentOS；OpenSSL；创建、配置、使用、吊销证书；报告列出 PKI 基本内容	第七部分
实验 7	学习 Docker 原理；安装 Docker；部署应用（例如开源防火墙，鼓励完成）；报告 Docker 基本内容与安全场景	第八部分

附录 B｜资料来源与使用边界

本复习指南主要依据用户提供的《网络信息安全实验.zip》中的原始 PDF：

- 实验 1 构建虚拟局域网.pdf
- 实验 2_常用网络安全管理工具.pdf
- 实验 3_Web 服务器安全.pdf
- 实验 4_网络漏洞检测.pdf
- 实验 5_密码应用.pdf
- 实验 5_密码应用_过程版.pdf
- 实验 6_公钥基础设施.pdf
- 实验 7_Docker 应用.pdf

并参考此前整理的配套学习材料：实验 1—4 初学者学习指南与简明分析；PGP/GnuPG 初学者学习指南与详细分析；PKI 初学者学习指南与详细分析；Docker 初学者学习指南与详细分析。

边界说明：原始实验没有提供课堂 PPT、正式考试大纲、教师命题范围或试卷样例。部分实验参考资料较旧，尤其是 Windows 管理命令、Sniffer 界面和 IIS 安全设置。本指南保留实验原意，同时对已过时或有风险的操作标注版本/安全边界。涉及具体命令时，示例仅用于理解，不代表适用于所有系统版本。

学习建议：先理解每章“为什么”，再背诵术语和命令；每道题尝试用自己的话回答。若只能复述句子却不能解释概念之间的关系，应回到对应知识图重新学习。